Trabajo sobre los log

Ataques al visor de sucesos de Windows

El visor de sucesos de Windows es una herramienta muy útil para diagnosticar problemas en el sistema operativo y las aplicaciones en ejecución. Sin embargo, también puede ser objetivo de ataques malintencionados que buscan comprometer la seguridad del sistema.

A continuación, se describen algunos posibles ataques al visor de sucesos de Windows:

Suplantación de identidad: un atacante puede suplantar la identidad de un usuario legítimo y acceder al visor de sucesos para ver información confidencial o realizar cambios maliciosos.

Denegación de servicio: los ataques de denegación de servicio (DoS) pueden apuntar al visor de sucesos para abrumarlo con solicitudes de información, lo que provoca que el sistema se vuelva lento o incluso se bloquee.

Sobrecarga de registros: un atacante puede enviar una gran cantidad de registros falsos al visor de sucesos para saturarlo y dificultar la detección de eventos legítimos.

Inyección de código: un atacante puede intentar inyectar código malicioso en el visor de sucesos para ejecutarlo en el contexto del sistema operativo y obtener privilegios elevados.

Falsificación de registros: un atacante puede modificar registros existentes en el visor de sucesos para ocultar actividades maliciosas o manipular la información registrada.

Borrando las huellas: limpiando el log de eventos de Windows

En Windows, el log de seguridad es solo escribible por el servicio LSASS (Local Security Authority Subsystem Service) y no hay funciones del API de Windows para interactuar con los eventos, es decir, necesitaremos ser administradores locales o de dominio o directamente SYSTEM. Además, en Windows, los eventos no pueden borrarse individualmente, tiene que ser todo o nada. Cuando los borremos se generará posteriormente un evento de tipo "log clear", con id 1102 en security o 104 en sistema (en windows XP/203 517).

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

Mimikatz

Mimikatz por ejemplo permite el comando event::clear: y sobre todo event::drop que realmente lo que hace es parchear el servicio del log de eventos y dejar de meter registros en Security. Lo bueno es que no añade el evento 1102 después de hacerlo, lo malo es que no permite volver a reanudar el logging por lo que un azulón forense nos acabará pillando y descubriendo que algo ha pasado en la máquina objetivo.

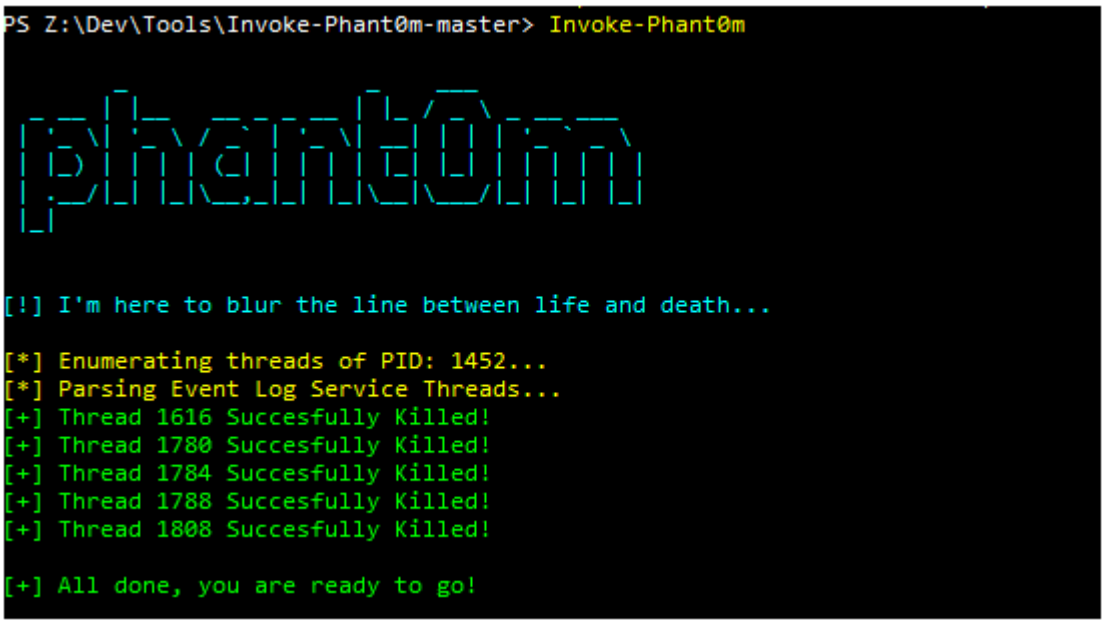


Línea de comando mimikatz [captura de pantalla]

Invoke-Phant0m

Se trata de un script en PowerShell que se utiliza para eliminar el hilo del proceso svchost responsable del registro de eventos. Esta técnica es buena para detener muchos controles de seguridad, no solo el visor de eventos. Lo que "mola" es que el servicio parece seguir funcionando cuando realmente ya no está registrando ningún evento.

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.



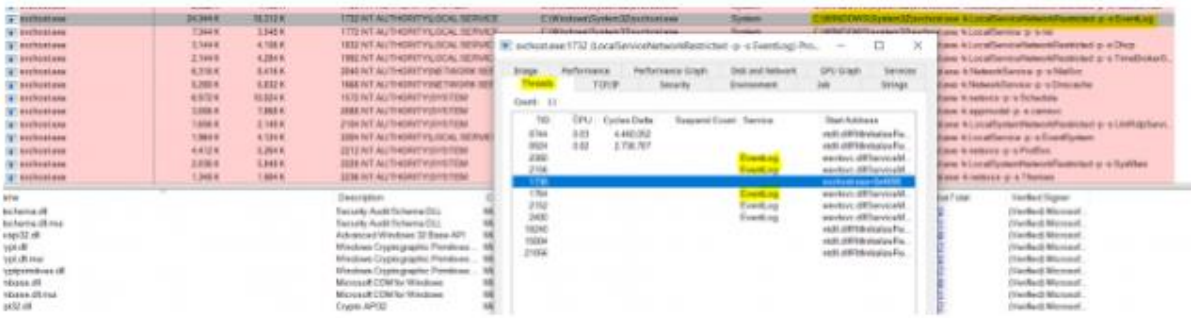
Programa Phant0m [captura de pantalla]

Terminar el proceso de Event Log

El proceso responsable para loggear eventos es:

```
svchost -k LocalServiceNetworkRestricted -p -s eventlog
```

Si suspendemos este proceso, el visor de eventos se pausará. Aunque tampoco podremos abrir un nuevo CMD o PowerShell podremos seguir usando una shell ya abierta. Eso sí, el visor de eventos se pausará, pero los registros aparecerán justo después de reanudar el proceso, lo mismo si mata el proceso y luego inicia los servicios nuevamente.

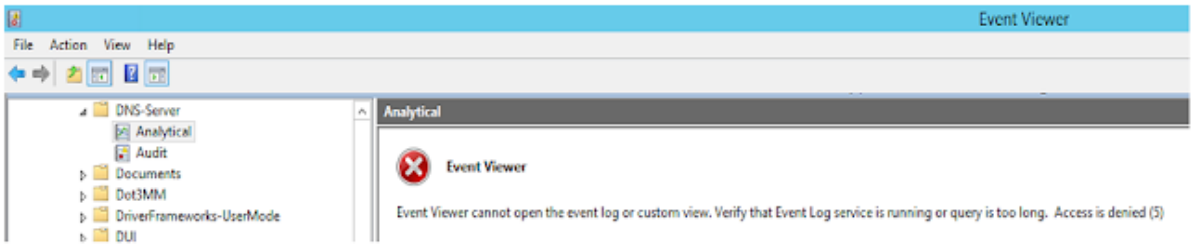


Aplicaciones en ejecución [Captura de pantalla]

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

Downgrade de componentes de Windows

La presencia de la clave de registro MiniNT (HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\MiniNT) hace que varios componentes de Windows crean que se están ejecutando en el entorno de preinstalación de Windows. Significativamente, la presencia de esta clave rompe el Visor de eventos; intenta abrir cualquier registro y recibirás el siguiente mensaje de error:



EventView de Windows [Captura de pantalla]

Además, si esto no fuera suficiente, la comunicación remota de Windows PowerShell también dejará de funcionar con esta clave.

DanderSpritz

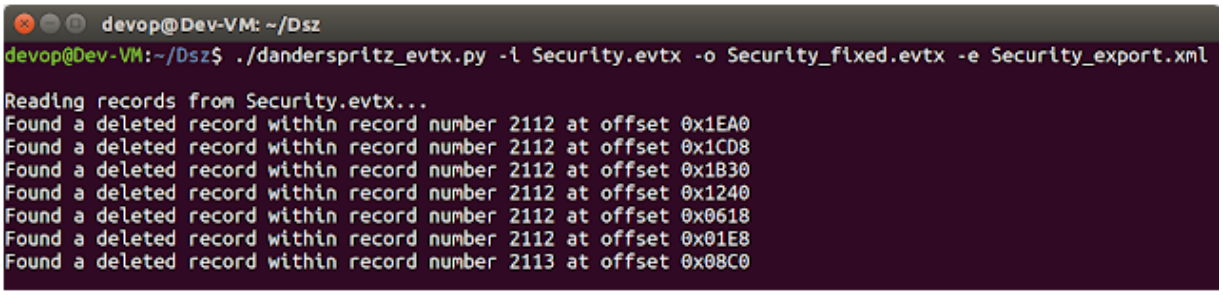
Shadow Brokers exfiltró este implante funcional que incluía una herramienta llamada "EventLogEdit". EventLogEdit era más sofisticada en comparación con otras, ya que permite eliminar entradas individuales de los registros de seguridad, aplicación y sistema sin dejar pistas obvias de que los archivos se han editado.

Desde China 3gstudent evolucionó además EventLogEdit para reescribir logs mediante la WinAPI EvtExportLog:

https://github.com/3gstudent/Eventlogedit-evtx--Evolution

También hay una interesante herramienta forense para descubrir si se ha usado DanderSpritz: https://github.com/fox-it/danderspritz-evtx

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.



Ejecución de DanderSpritz [captura de pantalla]

https://svch0st.medium.com/event-log-tampering-part-1-disrupting-the-eventlog-service-8d4b7d67335c

https://svch0st.medium.com/event-log-tampering-part-2-manipulating-individual-event-logs-3de37f7e3a85

Eliminando rastros en Linux

Una de las principales habilidades que debe tener un hacker es saber ocultar su rastro para evitar que los investigadores o expertos en ciberseguridad y forense digital puedan detectar su identidad. Estas técnicas se vuelven mucho más importantes en caso de que los cibercriminales deseen acceder a un sistema comprometido en el futuro.

Antes de continuar, recordamos que este artículo fue elaborado con fines informativos y no debe ser tomado como un llamado a la acción, por lo que IICS no es responsable del mal uso que pueda darse a la información aquí contenida.

Crear un directorio oculto fácilmente extraíble

Después de obtener acceso root, es posible crear un directorio oculto para trabajar y almacenar cualquier script o archivo en él, mencionan los expertos en ciberseguridad y forense digital.

Por un lado, estas acciones pueden pasar desapercibidas para los administradores de sistemas novatos, por lo que en determinados escenarios se requerirán mayores habilidades. Primero, busquemos todos los directorios manipulables usando el siguiente comando:

Bash es una popular interfaz de usuario de línea de comandos capaz de mantener en la memoria una lista de los comandos utilizados en la sesión actual, por lo que estos datos

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

son el primer objetivo a eliminar para cubrir nuestros pasos. Empleando el comando history, podremos ver los detalles de la más reciente actividad en el sistema:

```
root@target:/# history
  1  cd /
  2  ls
  3  find / -perm -222 -type d 2>/dev/null
  4  cd /dev/shm/
  5  cd /
  6  mkdir /dev/shm/.secret
  7  ls -l /dev/shm/
  8  ls -la /dev/shm/
  9  ls
 10  rmdir /dev/shm/.secret/
 11  history
```

Los comandos se escriben en la variable de entorno **HISTFILE**, generalmente **.bash_history**. Podemos usar el comando echo para encontrar la ubicación, señalan los expertos en ciberseguridad y forense digital:

```
root@target:/# echo $HISTFILE
/root/.bash_history
```

A continuación, usaremos el comando unset para eliminar la variable:

```
root@target:/# unset HISTFILE
```

Repitiendo de nuevo el procedimiento, vemos que no aparecen datos en el historial:

```
root@target:/# echo $HISTFILE
```

Para evitar que se guarde el historial de comandos, también puede enviarlo a /dev/null. Para hacer esto, establecer la variable:

```
root@target:/# HISTFILE=/dev/null
```

O haga lo mismo con el comando export:

```
root@target:/# export HISTFILE=/dev/null
```

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

El historial ahora se enviará a /dev/null (en otras palabras, a ninguna parte):

root@target:/# echo $HISTFILE

/dev/null

Establecer el número de comandos que persistirán durante la sesión actual en 0 usando la variable HISTSIZE:

root@target:/# HISTSIZE=0

De otro modo, se puede usar el comando export:

root@target:/# export HISTSIZE=0

Cambiar el número de líneas permitidas en el historial usando la variable HISTFILESIZE. Establecer este valor en 0:

root@target:/# HISTFILESIZE=0

O bien usar export:

root@target:/# export HISTFILESIZE=0

Según los expertos en ciberseguridad y forense digital, puede utilizar el comando set para cambiar los parámetros del shell. Para deshabilitar la opción de historial, usar el siguiente comando:

root@target:/# set +o history

Para encender el historial de nuevo:

root @ target: / # set -o history

De manera similar, se puede usar el comando shopt para cambiar las opciones del shell. Para deshabilitar el historial, usar el siguiente comando:

root@target:/# shopt -ou history

Encender otra vez:

root@target:/# shopt -os history

Al ejecutar comandos en el sistema objetivo, a veces es posible evitar almacenarlos en el historial ejecutando el comando con un espacio inicial:

root@target:~# cat /etc/passwd

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

Este método no siempre funciona y depende del sistema. También es posible borrar el historial simplemente con el switch -c:

root@target:~# history –c

Para asegurarse de que los cambios se escriban en el disco, utilizar el switch -w:

root@target:~# history –w

Estas acciones solo borrarán el historial de la sesión actual. Para asegurarse de que se borre el historial cuando cierre la sesión, los expertos en ciberseguridad y forense digital recomiendan usar el siguiente comando:

root@target:/# cat /dev/null > ~/.bash_history && history -c && exit

También se puede usar el comando kill para salir de la sesión sin guardar el historial:

root@target:/# kill -9 $$

Limpiar archivos de registro

Además del historial de Bash, también necesita limpiar los registros para pasar desapercibido, señalan los expertos en ciberseguridad y forense digital. A continuación, se muestran algunos archivos de registro comunes y su contenido:

/var/log/auth.log – Autenticación

/var/log/cron.log Cron – Tareas

/var/log/maillog – Correo

/var/log/httpd – Apache

Es posible eliminar el registro usando el comando rm:

root@target:/# rm /var/log/auth.log

Este proceso es poco recomendable, ya que podría levantar sospechas. Por tanto, se recomienda dejar el archivo vacío en lugar de eliminarlo por completo; para ello, puede usar el comando truncate y reducir el tamaño del archivo a 0:

root@target:/# truncate -s 0 /var/log/auth.log

Es necesario considerar que la función truncate no siempre está presente y no en todos los sistemas.

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

Se puede hacer lo mismo asignando “nada” al archivo:

root@target:/# echo '' > /var/log/auth.log

Y también use > para limpiar un archivo:

root@target:/# > /var/log/auth.log

También podemos enviarlo a /dev/null:

root @ target: / # cat/dev/null>/var/log/auth.log

O use el comando tee:

root@target:/# true | tee /var/log/auth.log

También puede usar el comando dd para no escribir nada en el archivo de registro:

root@target:/# dd if=/dev/null of=/var/log/auth.log

0+0 records in

0+0 records out

0 bytes (0 B) copied, 6.1494e-05 s, 0.0 kB/s

El comando shred se puede utilizar para sobrescribir un archivo con datos binarios sin sentido:

root@target:/# shred /var/log/auth.log

Además, puede agregar -zu para truncar el archivo y sobrescribirlo con ceros:

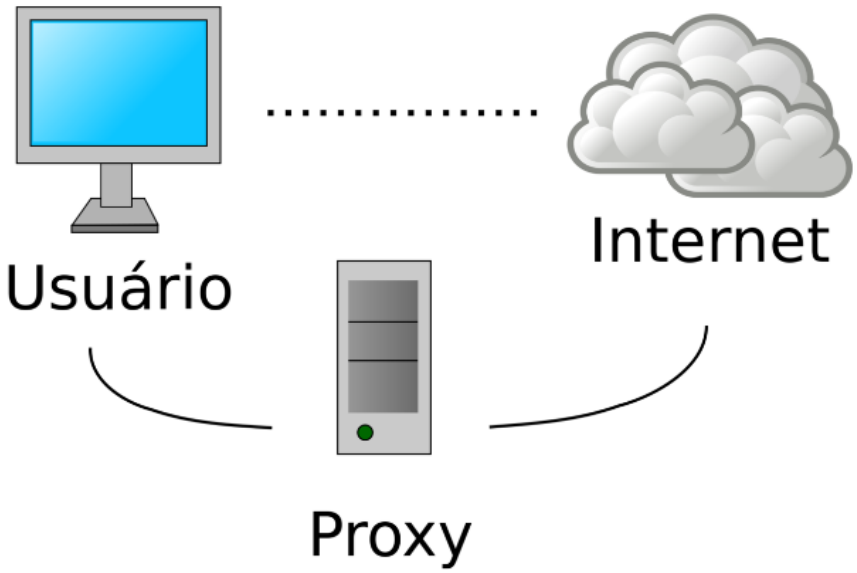
root@target:/# shred -zu /var/log/auth.log

Proxy

Un proxy es un servidor que actúa como intermediario entre un cliente y otros servidores a los que el cliente desea acceder. Cuando un cliente realiza una solicitud a través de un proxy, el proxy reenvía la solicitud al servidor correspondiente y luego reenvía la respuesta del servidor al cliente. El uso de un proxy puede tener varios beneficios, como mejorar la velocidad de acceso a Internet, mejorar la seguridad de la red y permitir el acceso a contenido restringido geográficamente. Los proxies se utilizan comúnmente en

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

redes corporativas, institucionales y gubernamentales para controlar y supervisar el tráfico de red. También hay proxies públicos disponibles para el uso general en Internet.



Fuente de imagen: Esquema de funcionamiento de un proxy.
https://commons.wikimedia.org/wiki/File:Esquema-proxy-internet.svg

Los proxies tienen varios usos, algunos de los cuales incluyen:

- Mejorar la velocidad y el rendimiento: los proxies pueden almacenar en caché contenido web frecuentemente utilizado para que el acceso a ese contenido sea más rápido y eficiente.
- Filtrado de contenido: los proxies pueden ser configurados para bloquear o filtrar contenido no deseado o peligroso, como sitios web maliciosos o contenido para adultos.
- Acceso a contenido restringido geográficamente: algunos servicios de Internet, como servicios de streaming de video, pueden restringir su contenido a ciertas regiones geográficas. El uso de un proxy puede permitir que el usuario final acceda a contenido restringido.
- Mejorar la privacidad: los proxies pueden ocultar la dirección IP real del cliente, lo que proporciona cierto grado de privacidad y anonimato en línea.
- Control y supervisión de la red: los proxies también se utilizan comúnmente en redes corporativas, institucionales y gubernamentales para controlar y supervisar

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

el tráfico de red, como verificar el uso de Internet por parte de los empleados y evitar el acceso no autorizado a sitios web y servicios en línea.

Es posible utilizar un proxy para ocultar ataques de red y evitar su detección. Al enrutar el tráfico a través de un proxy, la dirección IP real del atacante se oculta, lo que puede dificultar su rastreo y descubrimiento. Esto puede permitir a un atacante realizar actividades maliciosas, como escanear y explotar vulnerabilidades en otros sistemas, sin ser detectado. Es por eso que los proxies a menudo se utilizan en ataques de Man in the Middle (MitM), ataques de fuerza bruta y otros tipos de ataques cibernéticos. Sin embargo, es importante tener en cuenta que el uso de un proxy para realizar actividades maliciosas es ilegal y puede resultar en sanciones legales graves. Además, el uso de proxies también puede ser detectado y monitoreado por los sistemas de seguridad y las autoridades competentes.

¿Qué es Proxychains?

Proxychains es una herramienta de código abierto utilizada para enrutar conexiones de red a través de múltiples servidores proxy. Esta herramienta se utiliza comúnmente en el pentesting y la ciberseguridad para mejorar la privacidad, la anonimidad y la seguridad de las comunicaciones de red.

Proxychains funciona interceptando las conexiones de red salientes desde una aplicación o sistema operativo y redirigiéndolas a través de una cadena de servidores proxy configurados. Cada servidor proxy en la cadena puede proporcionar una capa adicional de anonimato y seguridad, ocultando la dirección IP y la identidad del usuario final.

Proxychains admite una amplia gama de protocolos de red, incluidos TCP, UDP y DNS, y es compatible con una variedad de servidores proxy, incluidos SOCKS4, SOCKS5, HTTP y HTTPS. La herramienta también admite la resolución de nombres de dominio remoto a través de servidores DNS proxy.

Cabe destacar que, aunque el uso de Proxychains puede mejorar la privacidad y la seguridad de las comunicaciones de red, su uso para fines malintencionados o ilegales puede resultar en consecuencias legales graves. Es importante utilizar esta herramienta con responsabilidad y ética.

Proxychains es una herramienta de código abierto que se utiliza comúnmente en sistemas operativos Linux para enrutar conexiones de red a través de múltiples servidores proxy. La herramienta se integra con la mayoría de las aplicaciones y herramientas de línea de

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

comandos en Linux y puede proporcionar una capa adicional de privacidad y seguridad para las comunicaciones de red.

Para utilizar Proxychains en Linux, primero es necesario instalar la herramienta en el sistema. Esto se puede hacer mediante el administrador de paquetes del sistema, como APT o Yum, o mediante la descarga y compilación del código fuente de la herramienta.

Una vez que Proxychains esté instalado, es necesario configurar la cadena de servidores proxy a través de la cual se redirigirán las conexiones de red. Esto se puede hacer mediante la edición del archivo de configuración de Proxychains (/etc/proxychains.conf) y agregando los detalles de los servidores proxy a utilizar. Por ejemplo:

sudo apt-get install proxychains

El archivo a configurar será: /etc/proxychains.conf

En el que al final de este especificaremos el protocolo por el que se conectaría y la IP del servidor, que obtendremos a través de esta web: https://hidemy.name/es/proxy-list/

Un ejemplo de este archivo sería el siguiente:



Configuración [captura de pantalla]

Una vez configurado todo correctamente, solo tendremos que acceder mediante un comando desde terminal se ha de ser usuario normal, no root y escribimos el siguiente comando:

proxychains [motor de búsqueda] [página web]

De esta forma especificaremos el cómo y el dónde estableceremos la conexión anónima.

Un ejemplo de este comando sería:

proxychains google-chrome www.google.com

Agregar el servidor proxy SOCKS4 en localhost:9050

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.

socks4 127.0.0.1 9050

Agregar el servidor proxy HTTP en proxy.example.com:8080

http proxy.example.com 8080

Una vez que se haya configurado Proxychains, es posible ejecutar aplicaciones y herramientas de línea de comandos a través de la herramienta. Para hacerlo, simplemente se debe ejecutar el comando precedido de "proxychains", como se muestra a continuación:

proxychains curl http://www.example.com

En este ejemplo, la herramienta Curl se ejecutará a través de Proxychains y se redirigirá a través de los servidores proxy configurados en el archivo /etc/proxychains.conf. De esta forma, se puede proporcionar una capa adicional de anonimato y seguridad a las comunicaciones de red.

© Universidad de Palermo. Prohibida la reproducción total o parcial de imágenes y textos.